

POLICY_02_data_privacy

MERIDIAN TRUST BANK

POLICY: DATA PRIVACY & SECURITY

Field	Value
Document ID	BNK-SEC-POL-02
Version	1.0
Effective Date	20/5/2026
Department	Information Security & Privacy Office

1. Scope

Applies to all bankers, fraud analysts, and operations associates handling customer Non-Public Personal Information (NPI). Complies with Gramm-Leach-Bliley Act (GLBA), Right to Financial Privacy Act, Bank Secrecy Act, FCRA, CCPA, GDPR (for EU-resident customers), and PCI-DSS for card data. Violations carry disciplinary consequences up to termination and may be examination-reportable.

2. Rules

2.1 Recording & Privacy Disclosure

ID	Rule	Severity
BNK-SEC-RULE-001	Banker must state the recording notification verbatim at call start if not played by IVR: ‘Please note this call is recorded for quality assurance and regulatory compliance purposes.’	CRITICAL
BNK-SEC-RULE-002	When opening a new account or collecting any new NPI from the customer, banker must state: ‘Your information is used solely to provide and service your accounts, in accordance with our Privacy Notice and applicable law. You may	MAJOR

ID	Rule	Severity
	receive a copy of our Privacy Notice at any time on request.'	

2.2 Payment Card Data (PCI-DSS)

ID	Rule	Severity
BNK-SEC-RULE-003	Banker must never read back a full debit card, credit card, or account number to a customer under any circumstances. Only the last 4 digits may be referenced.	CRITICAL
BNK-SEC-RULE-004	Banker must never ask for, record, or repeat a card CVV/CVC code.	CRITICAL
BNK-SEC-RULE-005	When activating a new card or processing a card-related transaction, banker must use the secure tone-capture system; no card data may be spoken aloud by the customer over an unencrypted line.	CRITICAL

2.3 Data Handling in Notes

ID	Rule	Severity
BNK-SEC-RULE-006	Case notes must mask all sensitive identifiers. Correct: 'Customer verified via card ending in 4729.' Writing full card numbers, full account numbers, full SSN, or security challenge phrases is a CRITICAL violation.	CRITICAL
BNK-SEC-RULE-007	Banker must not export, screenshot, photograph, or copy any customer NPI to personal devices, personal email, or unauthorized cloud services.	CRITICAL

2.4 Verification Before Access

ID	Rule	Severity
BNK-SEC-RULE-008	Banker must never confirm whether a customer holds an account, what types of accounts they hold, or whether a specific person is on an account, to any unverified caller. Doing so is a GLBA data exposure violation.	CRITICAL
BNK-SEC-RULE-009	Credential resets (online banking password, security challenge phrase, debit card PIN) may only be performed after successful 3-of-5 identity verification. If verification cannot be completed by phone, customer must visit a Meridian Trust branch in person with a government-issued photo ID.	CRITICAL

2.5 Suspected Unauthorized Access

ID	Rule	Severity
BNK-SEC-RULE-010	If unauthorized account access is suspected, the banker must, on the same call: (1) freeze all account changes and outbound transfers, (2) flag the account as 'Security Review' in the system, (3) open a Fraud Operations ticket, (4) advise the customer to change online banking credentials and any reused passwords. Fraud Ops follows up within 4 hours. The banker must not perform any further account changes on this call beyond the freeze.	CRITICAL

2.6 Data Retention

Data Type	Retention Period	Action After Period
Call audio recordings	7 years (FFIEC)	Permanently deleted
Call transcripts and case notes	7 years	Anonymized and archived

Data Type	Retention Period	Action After Period
Customer NPI (active customers)	Life of account + 7 years	Purged per GLBA Safeguards Rule
AML/BSA records (CTR, SAR)	5 years from filing	Retained per BSA

ID	Rule	Severity
BNK-SEC-RULE-011	Customer data deletion requests under CCPA/GDPR must be flagged as ‘Privacy Deletion Request’ and routed to the Privacy Office via ticket. Records subject to regulatory retention (BSA, FFIEC, CTR/SAR) cannot be deleted before their retention period expires; bankers must explain this distinction to the customer in plain language.	MAJOR

2.7 Cross-Border Data

ID	Rule	Severity
BNK-SEC-RULE-012	For EU-resident customers exercising GDPR rights, banker must not provide any answer or commitment on the call; route immediately to the Privacy Office ticket. The Privacy Office responds within 30 calendar days as required by GDPR Article 12.	MAJOR